

SecureBase™ Cloud Technical Safeguards Assessment

Evaluation Standard: FFIEC IT Examination Handbook (AIO & InfoSec Booklets) & Post-CAT Supervisory Standards

Architecture Archetype: Regional & Community Financial Institutions (\$1B – \$15B Assets | Cloud-Native & Hybrid)

Target Entity: Regional Bank (Architecture Archetype)	Regulatory Framework: FFIEC AIO, InfoSec & GLBA Safeguards
Asset Scale: \$1B – \$15B (Texas & Regional Profile)	Supervisory Scope: Texas DOB, FDIC, OCC & FRB Continuous Exam
Assessor / Author: Cedrick J. Byrd, Principal Cloud Architect	Publication Date: September 2026 (Post-CAT Supervisory Guidance)
Platform: SecureBase™ Compliance Control Plane	Inspection Architecture: 100% In-Tenant Read-Only (Zero NPI Egress)

1. Executive Summary & Post-CAT Compliance Scorecard

With the official retirement of the FFIEC Cybersecurity Assessment Tool (CAT), financial regulatory agencies (Texas Department of Banking, FDIC, OCC, and Federal Reserve) have transitioned from static periodic self-assessments to **continuous architectural examination**. Under the updated **FFIEC Architecture, Infrastructure, and Operations (AIO)** and **Information Security** booklets, examiners now expect live, cryptographically verifiable evidence proving that cloud workloads enforce least-privilege access, immutable audit logging, and continuous configuration integrity.

This reference assessment models the actual cloud infrastructure baseline of a representative Texas regional financial institution (\$1B–\$15B assets). Evaluated via the **SecureBase™ Governance Engine**—which operates strictly via read-only cloud metadata and configuration APIs with **zero access to, ingestion of, or transmission of customer financial records (NPI)**—the archetype demonstrates strong perimeter and identity maturity (84/100). However, typical regional bank estates exhibit critical vulnerabilities in **audit log immutability (lack of 7-year WORM compliance vaults)**, **unmanaged console drift bypassing Terraform pipelines**, and **Customer Managed Key (CMEK) enforcement** on secondary analytics storage.

FFIEC Control Domain	Regulatory Citation	Technical Control Scope	Supervisory Status	Score
Identity & Access (IAM)	AIO §II.C / InfoSec §II.A	IAM Least Privilege, Okta/Azure SSO, Break-Glass Roles	SATISFIED	90%
Audit & Non-Repudiation	AIO §II.D / InfoSec §II.C	Multi-Region CloudTrail, 7-Year WORM S3 Vault	CRITICAL GAP	70%
Infrastructure Drift Control	AIO §II.E / Operations	IaC State Drift, Terraform Pre-Flight Validation (MCP)	ACTION REQ.	76%
Cryptographic Protection	InfoSec §II.B / GLBA	AWS KMS CMEK, 365-Day Key Rotation Across S3/RDS	SATISFIED	92%
Resilience & Perimeter	AIO §II.B (Business Continuity)	TLS 1.3 In Transit, Multi-AZ Failover, Ingress Hardening	SATISFIED	94%
Composite Posture	Overall Rating	FFIEC Cloud Technical Safeguards Baseline	SUBSTANTIAL	84 / 100

2. Detailed Control Findings & Examiner Evidence Matrix

FFIEC Control Domain	Technical Requirement	Observed Cloud Archetype Baseline	Examiner Risk & Remediation
----------------------	-----------------------	-----------------------------------	-----------------------------

Identity & IAM Boundaries (AIO §II.C)	Enforce least privilege and restrict administrative permissions across cloud management consoles.	Centralized Okta / Entra ID SSO mapped to AWS IAM Identity Center. Role-based boundaries active for engineering.	Fully Aligned. Temporary credentials enforced. Emergency break-glass roles configured with CloudWatch alerts.
Audit Log Non-Repudiation (InfoSec §II.C)	Maintain immutable, tamper-evident audit logs of all security-relevant configuration changes.	AWS CloudTrail active multi-region; logs centralized in security S3 bucket. Lacks WORM compliance lock.	Critical Deficiency: Central logs lack S3 Object Lock in COMPLIANCE mode . Logs vulnerable to deletion. Deploy 7-year WORM vault.
Infrastructure Drift Control (AIO §II.E)	Prevent unauthorized configuration changes between documented baseline and production state.	Core infrastructure deployed via Terraform. Periodic manual console modifications detected in non-prod.	Shift-Left Action: Deploy securebase-mcp into developer IDEs to catch Terraform drift prior to pipeline deployment.
Data at Rest Cryptographic Keys (InfoSec §II.B)	Encrypt customer records using customer-controlled keys with automated rotation.	Core databases utilize AWS KMS CMEK. Secondary data exports utilize standard SSE-S3 encryption.	Remediation Required: Enforce KMS Customer Managed Keys with 365-day rotation across all S3 storage buckets.
Transmission & Perimeter Security (AIO §II.B)	Enforce secure transmission protocols across all digital banking and administrative sessions.	TLS 1.3 enforced across public load balancers and API Gateways. Ingress restricted via Security Groups.	Fully Aligned. Deprecated SSL/TLS ciphers disabled. Direct HTTP requests dropped at perimeter.

3. Priority Remediation Roadmap & SecureBase™ Solutions

To insulate regional financial institutions from Matters Requiring Attention (MRAs) and supervisory findings during state and federal examinations, TxImhotep recommends executing the following three technical remediations within 30 days:

Priority & Target Finding	Supervisory Risk to Institution	SecureBase™ Automated Remediation Code / Action
PRIORITY 1: CRITICAL Audit Log Mutability (InfoSec §II.C)	CloudTrail logs stored without immutable object retention can be overwritten or deleted during privileged account compromise, failing FFIEC non-repudiation mandates.	Deploy Immutable WORM Vault: Provision an Amazon S3 Object Lock vault in COMPLIANCE mode with a mandatory 7-year retention period and KMS Customer-Managed Key (CMEK) policy. Enforces tamper-proof log protection.
PRIORITY 2: HIGH Pre-Deployment Drift (AIO §II.E)	Console modifications in cloud environments create discrepancy between approved Terraform architecture and live infrastructure, failing regulatory configuration controls.	Shift-Left IDE MCP Toolchain: Deploy securebase-mcp to engineering workstations. Pre-flight checks Terraform plans (validate_terraform_plan) in Cursor/VS Code before code enters pull requests.
PRIORITY 3: MEDIUM Secondary S3 Key Scoping (InfoSec §II.B)	Secondary analytics buckets relying on default SSE-S3 lack cryptographic access separation, exposing operational backups to broad internal cloud service roles.	Enforce CMEK Bucket Guardrails: Deploy automated SCP / S3 bucket policies requiring s3:x-amz-server-side-encryption-aws-kms-key-id on all PUT requests with automated 365-day rotation.

4. Data Sovereignty & Zero-NPI Access Guarantee

TxImhotep LLC Sovereign Architecture Declaration:

This assessment and the underlying SecureBase™ platform operate strictly via **read-only metadata inspection** (AWS Config, CloudTrail configurations, S3 bucket policies, and IAM role trust relationships). At no point does SecureBase inspect, ingest, decrypt, cache, or transmit customer financial records, core banking data, or GLBA-regulated Non-Public Personal Information (NPI). All telemetry remains 100% sovereign within the institution's cloud perimeter, eliminating third-party data risk and satisfying bank vendor risk management guidelines.

5. Commercial Engagement & Rapid 72-Hour Delivery

Regional institutions can immediately operationalize these controls through the **SecureBase Assessment (\$3,500 flat fee)**. Executed via a straightforward 1-page commercial agreement that sits within standard departmental credit card / discretionary expense limits, TxImhotep delivers:

- **Day 1:** Delivery of the securebase-mcp developer toolchain for local Terraform plan validation in Cursor/VS Code.
- **Day 2:** Provisioning of the 7-year immutable S3 Object Lock compliance vault (COMPLIANCE mode).
- **Day 3:** Delivery of the complete, cryptographically verified FFIEC IT Handbook Evidence Binder for DOB/OCC examiners.

100% Payout Credit: The entire \$3,500 evaluation fee is credited 100% toward an annual SecureBase Enterprise Platform Subscription.

Interactive Portal: Inspect our live compliance dashboard simulator directly at <https://demo.securebase.tximhotep.com/compliance>.

Assessment Author: Cedrick Jurone Byrd Founder & CEO Principal Cloud Architect TxImhotep LLC cedrickjbyrd@gmail.com (214) 430-8800	Target Audience: Chief Information Officers (CIOs) Chief Information Security Officers (CISOs) VPs of IT & Cloud Infrastructure Regional Financial Institutions (Texas & National)
---	---